

WORKSHOP

Cibersegurança e Uso Responsável de Inteligência Artificial

Dados, decisões e agentes no contexto da OPIN

- Marcos Cassel · Application & Product Security



A segurança de IA não é uma questão teórica

Dados, identidade, decisões e operações já estão sendo afetados

A história

Um colaborador da Arup, em Hong Kong, participou de uma videochamada com quem pareciam ser o diretor financeiro e outros colegas.

Todos eram deepfakes gerados por IA. Ele seguiu as instruções e autorizou transferências para a organização. Ver e ouvir alguém em vídeo deixou de ser prova suficiente de que aquela pessoa é quem diz ser.

Esse e outros casos reais vão aparecer ao longo do workshop — com o que fazer a respeito.

além disso...

1 em cada 5

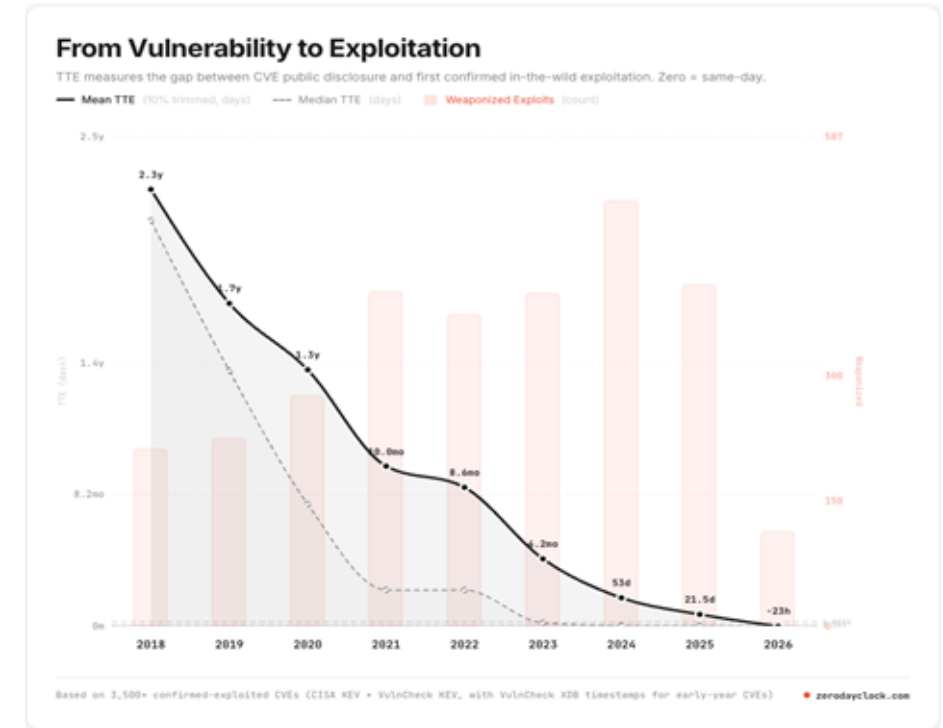
organizações já sofreu uma violação de dados ligada ao uso não autorizado de IA (shadow AI)

A janela entre achar e explorar uma falha está diminuindo

AI



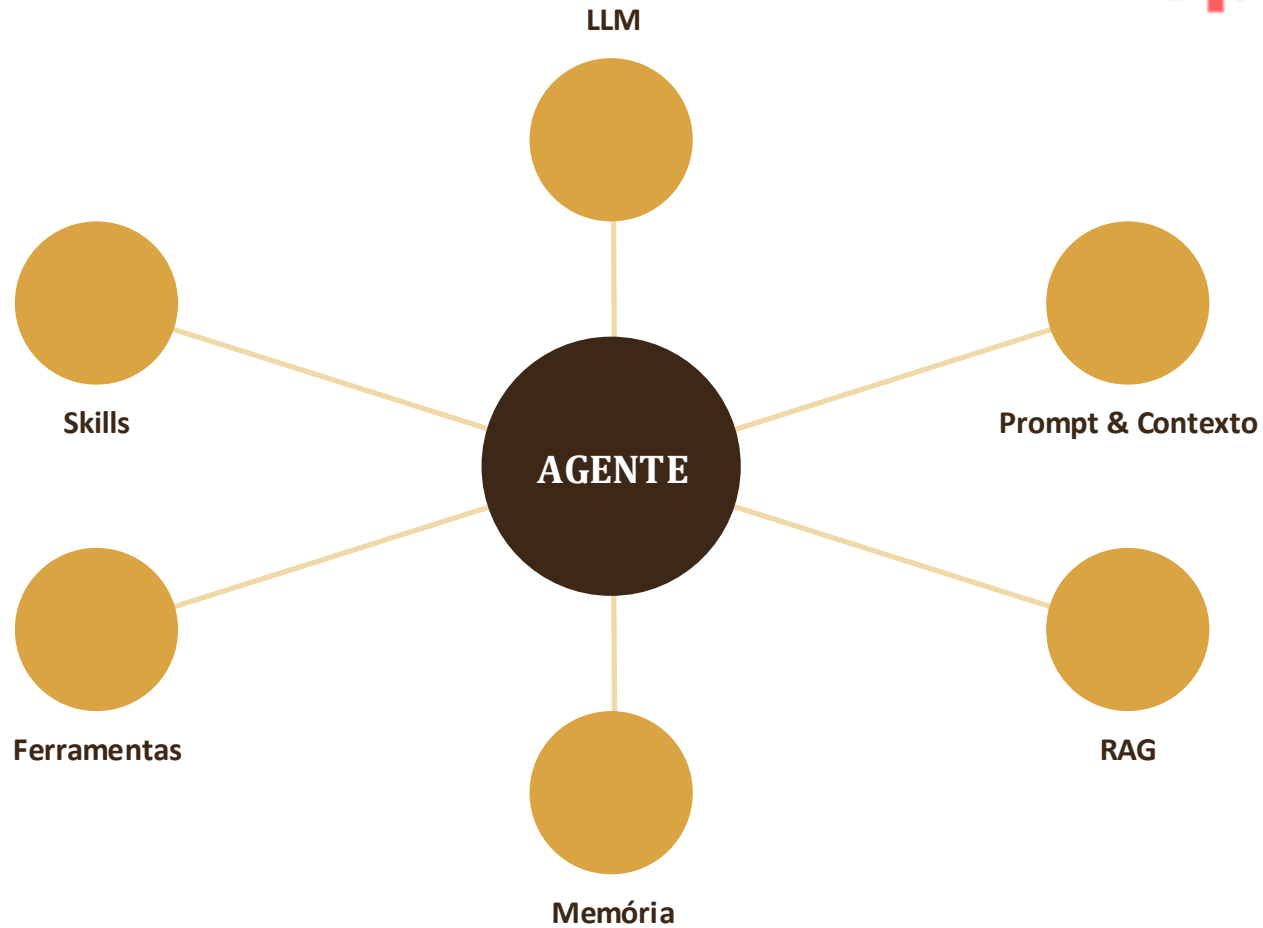
- Anthropic: o Claude Mythos Preview identificou e explorou vulnerabilidades zero-day em sistemas operacionais e navegadores amplamente usados
- UK AI Security Institute: avaliação independente observou forte avanço em tarefas especializadas e ataques simulados de múltiplas etapas
- Google Threat Intelligence Group (com a Mandiant, parte do Google Cloud): primeiro caso atribuído com alta confiança ao apoio de IA no desenvolvimento de um exploit zero-day



Quando uma organização conecta IA a dados, identidades, ferramentas ou produção, precisa reavaliar acesso, supervisão e impacto.

Anatomia de um agente de IA

O agente no centro depende de cada peça ao redor — e herda o risco de todas elas



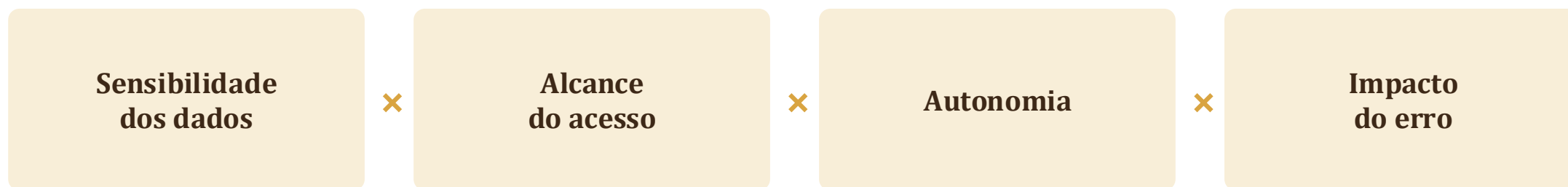
De uma resposta simples a uma ação autônoma



“Um chatbot responde. Um agente observa, decide e age — muitas vezes usando a identidade e as permissões de alguém.”

Nem toda IA carrega o mesmo risco

Qual destas situações tem mais risco: pedir à IA para revisar um texto público, enviar um documento interno para ela resumir, ou permitir que ela altere um sistema de produção?



Risco de IA é proporcional a essa combinação — não é fórmula matemática, é um modelo didático.

Uma IA que revisa um texto público tem um perfil de risco. A mesma IA conectada a SharePoint, Jira, GitHub, Azure, e-mail e dados de participantes tem um perfil completamente diferente.

Por que isso importa para a OPIN

- Infraestrutura de APIs que conecta o ecossistema de Open Insurance
- Ambiente tecnológico predominantemente Microsoft Azure
- Operação com forte participação de fornecedores e prestadores de serviço
- Chatbot interno e Norma de Uso de IA em desenvolvimento

Prioridades

- Security by Design e Zero Trust
- Uso de tecnologias seguras por padrão
- Monitoramento obsessivo
- Resposta a Incidentes a nível hospitalar

Dados e confidencialidade (vazamento de dados)

O custo real do shadow AI

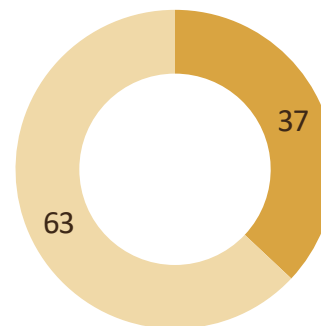
- Dados pessoais, código-fonte e credenciais podem vazar em prompts, anexos, memória e logs
- Caso histórico: colaboradores da Samsung enviaram código sensível a uma ferramenta pública de IA
- IBM (2025): 1 em cada 5 organizações teve violação relacionada a shadow AI



US\$ 670 mil

custo médio adicional em organizações com alto uso de shadow AI

Apenas 37% possuem
política para gerenciar shadow AI



■ Têm política ■ Não têm política

Antes de colar qualquer dado, faça estas 4 verificações

- 1 **Ambiente** — dados de trabalho só no workspace corporativo aprovado. Conta pessoal? Pare antes de enviar.
 - 2 **Treinamento**
 - ChatGPT: Data Controls → Improve the model for everyone: Off ·
 - Claude: Privacy → Help Improve our AI models: Off
 - 3 **Persistência** — não precisa de histórico ou memória? Use Chat Temporário ou Incógnito.
 - 4 **Exposição** — revogue links, apps e conectores
 - 5 **Acesso** — rative MFA e encerre sessões desconhecidas.
- ! **Desligar o treinamento reduz um risco. Não autoriza dados confidenciais.**



Acesso, permissões e autonomia: até onde a IA pode ir?

- Que identidade e credenciais a IA utiliza? A sua?
- A autorização é aplicada na fonte e por usuário?
- Existe segregação entre participantes e ambientes?
- A IA apenas lê ou também escreve, compartilha, executa ou exclui?
- Quais ações exigem confirmação humana?
- O acesso e a ação são temporários, revogáveis e reversíveis?

Caso real — Replit: um agente de programação apagou dados de produção apesar de uma ordem de congelamento — falha conjunta de segregação, aprovação humana e recuperação.



Prompt injection e envenenamento de contexto

- Instruções maliciosas podem chegar por e-mails, documentos, páginas web, tickets, código ou resultados de ferramentas
- Conteúdo externo pode ser interpretado pelo agente como instrução
- Risco de extração de dados, desvio da tarefa ou acionamento indevido de ferramentas

Caso real

EchoLeak · CVE-2025-32711 **Microsoft 365 Copilot**

Qualquer fonte de dados é avenida para o envenenamento de contexto de um agente. Neste caso, uma falha permitiu que através do texto de um e-mail, fosse possível infectar o Microsoft Copilot.

“Prompt injection não se resolve apenas com um prompt de sistema mais forte. São necessários controles de arquitetura, acesso, ferramentas e saída.”

Terceiros e cadeia de fornecimento

**Provedor do
modelo**

**Plataforma
de IA**

**Plugins, conectores
e skills**

**Modelos e bibliotecas
open source**

**Empresas que operam
a solução**

**Mudanças de versão
ou comportamento**

“Enterprise” não é sinônimo automático de “seguro”. Contratos, retenção, treinamento, suboperadores, residência de dados, resposta a incidentes e auditoria precisam ser avaliados. LGPD e requisitos do Open Insurance continuam aplicáveis.

Onde o risco entra no workflow?

	Responde	Consulta	Lembra	Conecta	Age	
Dados e confidencialidade						Atravessam todas as etapas
Acesso, permissões e autonomia						Crescem em Consulta, Conecta e Age
Prompt injection e contexto						Entram em Consulta, persistem em Lembra, impactam Conecta e Age
Terceiros e cadeia de fornecimento						Podem estar presentes em toda a cadeia

O risco não está isolado no modelo: ele entra, persiste e cresce junto com a capacidade da aplicação.

Checklist DADOS

Um mnemônico didático — não é framework oficial

D

Dados

Existem dados pessoais, segredos, código ou credenciais?

A

Acesso

O RAG respeita as permissões do usuário na fonte?

D

Decisão

A resposta apresenta fontes e será validada por alguém?

O

Operação

A IA apenas recomenda ou também executa? É reversível?

S

Supervisão

Há responsável, monitoramento e plano de resposta a incidentes?

Traduz recomendações do NIST AI RMF, OWASP Top 10 for LLM Applications, LGPD e do Manual de Segurança do Open Insurance em perguntas práticas.

Trazendo o risco para a OPIN

Cenário fictício

Uma organização adota um assistente de IA conectado a documentos internos. Um colaborador pede que ele analise um arquivo recebido de um fornecedor. O arquivo contém uma série de instruções diretas para o LLM e o assistente possui uma ferramenta capaz de executar uma alteração em outro sistema.

Em que etapa do workflow o risco entra? Quais dos quatro riscos estão presentes?



Dados

Quais informações estão em risco?



Acesso

Que acesso o agente realmente precisa?



Decisão

Quais respostas exigem validação humana?



Operação

Que ações não podem ocorrer automaticamente?



Supervisão

Como detectar, interromper e investigar o abuso?

Antes de construir ou integrar: controles mínimos

1

Caso de uso e dados

Finalidade aprovada, responsável, classificação e minimização

2

Contexto e acesso

Autorização na fonte, memória e retenção mínimas, conteúdo externo não confiável

3

Ação

Credenciais restritas, leitura por padrão e aprovação para ações de impacto

4

Resiliência

Testes, logs com redução de dados sensíveis, monitoramento, kill switch e rollback

5

Terceiros

Contratos, suboperadores, mudanças de versão, auditoria e resposta a incidentes

Cinco mensagens para levar daqui

- 1 Nem toda AI carrega o mesmo risco.
- 2 Não de acesso a uma agente de AI que você não daria a um estagiário ou a um estranho.
- 3 Utilize somente ferramentas autorizadas pela sua empresa ou pelo time de Segurança / Privacidade / Jurídico.
- 4 Trate conteúdo externo e a cadeia de fornecedores como superfícies de risco.
- 5 A responsabilidade permanece com a pessoa e com a organização.

Antes de usar, construir, integrar ou autorizar uma IA, avalie o risco.